# TASKTRACK SYSTEM

System Overview and Security Findings

Defense Brief | Prepared 16 October 2026

**Purpose.** Maikling gabay ito para maipaliwanag ang saklaw at daloy ng TaskTrack, kasama ang isang security weakness na natukoy sa static review. Hindi ito certification na ligtas ang buong production deployment.

**Executive summary: Ang TaskTrack ay PHP at MySQL web system na nag-uugnay ng employee records, attendance, payroll, recruitment, office tasks, production, at delivery. Isang medium-severity issue ang nakumpirma: maaaring mag-submit ng attendance punch para sa ibang employee gamit lamang ang kanilang Employee ID dahil walang authentication/identity proof ang attendance endpoint. Maaari nitong maapektuhan ang attendance record at payroll inputs.**

## System overview

Ang system ay binubuo ng PHP pages at form handlers, browser-side JavaScript/CSS, at MySQL/MariaDB database. Ang repository ay may XAMPP/local deployment instructions. Ang PHP backend handlers ay karaniwang nasa config/; ang uploaded documents at images ay nasa uploads/ at ang ilang protected files ay inihahatid sa pamamagitan ng PHP endpoint.

| Role | Gamit sa system |
|---|---|
| Administrator | Accounts, roles, employee links, account status, profile pictures, reports at system activity. |
| HR | Employee records, attendance review/correction, leave at recruitment/interview processing. |
| Payroll | Payroll records, calculations at payroll review confirmation. |
| Supervisor | Office, production at delivery task assignment at completion review. |
| Production / Cooking / Packaging | Production assignments at kani-kanilang stage updates. |
| Logistics | Assigned deliveries, status updates at delivery proof submission. |
| Employee | Personal office tasks, progress updates at completion submissions. |

## Main workflows

**1. Accounts and employee records:** Administrator creates role-based accounts and links them to employee profiles. HR maintains employee information.

**2. Attendance:** The public attendance page asks for an Employee ID and submits the next clock action. HR can correct attendance with a reason; records are later used by payroll.

**3. Leave and payroll:** HR records paid SIL or unpaid leave. Payroll calculates eligible work/leave amounts and confirms review status. A Paid status means reviewed in the system; it is not proof of an external cash or bank payout.

**4. Office tasks:** Supervisor assigns work. Employees update progress and submit completion for review.

**5. Production:** Supervisor assigns production work/stages; Production, Cooking and Packaging users update progress, then completion is reviewed.

**6. Delivery:** Supervisor assigns products/routes to drivers. Logistics updates delivery and submits proof; Supervisor approves or requests changes.

**7. Recruitment:** Applicants submit application details and resumes. HR reviews applications and schedules interviews.

**8. Notifications and history:** Task notifications and selected audit/activity records help trace important actions.

## Data and important boundaries

Core tables documented in the schema include users, employee, attendance, payroll, applicant, production, delivery, office and task_notifications. Leave uses employee_leave_requests. Personal data and applicant resumes are sensitive; protected resume and delivery-proof routes should remain access-checked. Leave/payroll values depend on recorded employee dates and attendance; the system documentation notes that older payroll records are not automatically recalculated after later leave changes.

## Security review result

**Review type:** Static, source-code review of selected changed request handlers and related security-sensitive flows. It was not a full line-by-line audit of every file and was not a live penetration test. No live production server, Apache settings, network boundary, database permissions, or session-cookie configuration were verified.

### Confirmed finding

| Severity | Finding |
|---|---|
| **MEDIUM**<br>Confidence 9/10 | **Unauthenticated attendance punching for arbitrary employees.**<br>The attendance handler accepts employee_id and action_type from a request and processes the next punch without requiring a signed-in user or checking that the requester is authorized for that employee. Anyone able to reach the endpoint can attempt attendance actions for another employee by supplying their Employee ID. The public kiosk flow appears intentional, but the application does not enforce a trusted kiosk boundary or independently verify employee identity. |
| Evidence | config/attendance_API.php lines 17-25 (request values), 121-129 (employee lookup), 227-237 and 273-278 (attendance writes); attendance_form.php lines 35-36, 104-109 and 156-162 (public caller); index.php line 144 (public link). |
| Impact | An attacker may falsify attendance records for another employee. Since attendance is an input to payroll calculation, this could cause incorrect payroll results or disputes. The handler uses server time and sequential punch logic, so the issue does not by itself allow arbitrary backdated times. |
| Exposure assumptions | The endpoint must be reachable and the database account must have its normal attendance write permission. A physically supervised kiosk on a restricted network lowers remote exposure, but an Employee ID alone does not stop a person at the kiosk from punching for someone else. |

### Recommended remediation

Do not treat Employee ID as proof of identity. Require an employee-specific second factor such as an individually issued PIN/QR credential, or require a signed-in account bound to the employee record.

If the business requires a shared kiosk, authenticate the kiosk server-side and restrict it to a managed device/network; still add employee identity verification and rate limits. Do not rely only on a hidden page or client-side checks.

Record the authenticated actor/kiosk identity with each punch, log denied/abnormal attempts, and have HR review exceptions before payroll is finalized.

Add tests for unauthenticated requests, attempts to punch another employee, valid kiosk/account flows, rate limiting and audit attribution.

### Suggested defense explanation

**"TaskTrack has separate role-based workflows for administration, HR, payroll, supervision, production, logistics and employees. The review found a medium-risk weakness in the public attendance kiosk: knowing an Employee ID is currently enough to attempt a punch for that person. We identified that attendance affects payroll, so we recommend verifying identity beyond the ID, constraining kiosk access server-side, and keeping auditable records. The review was static and limited; we are not claiming a complete penetration test or security certification."**

## Review scope and limitations

The reviewer inspected selected surfaces including config/Supervisor_API.php, config/application_API.php, config/attendance_API.php, config/Payroll_API.php, config/employee_API.php, new leave and attendance-correction handlers, delivery-proof and resume handling, and related HR, payroll, logistics and delivery pages. The bounded follow-up traced the public attendance form to the attendance endpoint.

The review did not comprehensively assess every repository endpoint. Explicitly not fully reviewed were config/Production_API.php, config/chatbot_API.php, config/forgot-password.php, config/reset-password.php, config/registerBE.php, and all admin, employee, notification, chart and account-management actions. Deployment configuration, real database permissions/schema, server exposure, kiosk controls, and runtime behavior were not tested. Findings should therefore be treated as a focused static assessment, not proof that other weaknesses do not exist.

### Controls noted in reviewed flows

Prepared statements are used in many inspected database operations.

Several protected pages check role and/or active-account status.

CSRF tokens are present in selected payroll, delivery-review and attendance-correction actions.

Resume and delivery-proof serving use protected PHP routes; reviewed upload handlers validate file type and size.

Apache upload rules deny direct access to private uploads, with narrow access for profile image formats.

The presence of these controls does not mean every route has been verified. Deployment settings must preserve them, and the attendance authorization gap remains the confirmed issue in this brief.

## Defense checklist

| Before defense/demo | Evidence to prepare |
|---|---|
| Show each role boundary | Demo one account per role and explain which pages/actions are allowed. |
| Explain attendance risk | Be transparent: Employee ID alone is not identity proof. Describe the proposed PIN/credential and kiosk controls. |
| Explain payroll semantics | Clarify that Paid is an in-system review confirmation, not a bank transfer receipt. |
| Explain uploads/privacy | Demonstrate protected resume/proof access and server-side type/size checks; avoid exposing real applicant data. |
| Show verification limits | Present tests and code review scope honestly. Do not call a static review a penetration test. |
| Operational security | Use non-default DB credentials outside local development, protect SMTP secrets, restrict network access, and test database plus uploads restore. |

**Source note:** Overview is based on repository README.md, DEPLOYMENT.md and config/install_schema.sql. Security finding is based on the delegated source review of the current worktree. File and line references identify the reviewed local source; re-check after code changes.

# Correction: attendance finding remains open

The prior remediation note in this PDF said that Employee ID plus an attendance PIN had been implemented. At the user's request, the PIN feature has now been removed from the application code and attendance form.

**The medium-severity attendance issue on page 3 is therefore not fixed: a public kiosk attendance request still identifies an employee by Employee ID, without independently verifying who is submitting the punch. A person who knows another employee's ID and can reach the kiosk may attempt to record attendance for that employee.**

Operational mitigation: keep the attendance page limited to a controlled, supervised kiosk and trusted network, and review attendance exceptions before payroll. These measures reduce exposure but do not establish the employee's identity. A proper technical fix requires an identity check beyond Employee ID.

Scope note: the review was a focused static source review, not a full repository audit, live penetration test, or assessment of the deployed network and server configuration.